

Access Control Policy

Audience: public. This document describes our approach to controlling access in general terms. It intentionally omits implementation details, identifiers, and internal procedures.

Version 1.0 · Last reviewed 2026-05-29 · Next review by 2027-05-29

Purpose

This policy states how we decide who — and what — may access our systems and the information they hold. It complements the broader Information Security Policy.

Scope

This policy applies to access by people and by systems across the services we operate, covering both routine operations and privileged administrative actions.

Our principles

- **Least privilege.** Access is limited to what is required to perform a task, and no more.
- **Need to know.** Access to sensitive information is granted only where there is a legitimate need.
- **Deny by default.** Requests are refused unless explicitly permitted. New systems and capabilities begin with no standing access.
- **Separation of duties.** Sensitive actions are structured so that no single party holds unchecked control.
- **Accountability.** Access is attributable, so that actions can be traced to the identity that performed them.
- **Strong, modern identity.** We favor phishing-resistant ways of confirming identity and are reducing reliance on shared secrets such as passwords.
- **Short-lived over standing access.** Where possible, access is granted as scoped, time-limited, and revocable rather than as long-lived shared credentials.

Identity and authentication

Every person and system must establish a verified identity before being granted access. Connections between our services are mutually authenticated, and access is refused where an identity cannot be confirmed.

We are implementing authentication that does not depend on memorized passwords, favoring stronger, phishing-resistant methods grounded in what a person or system holds and can cryptographically prove. We support federated sign-in, so that an identity established with a trusted provider can be relied upon without creating and storing separate credentials.

Authorization

Once authenticated, an identity is granted only the specific capabilities assigned to it. Permissions

are defined explicitly, and access to sensitive or administrative functions is restricted to a limited set of authorized identities.

Where one party acts on behalf of another, access is delegated through narrowly scoped, time-limited grants rather than shared credentials, so that a system operates only within the specific permissions and for the limited window it has been given.

Privileged and administrative access

Administrative capabilities are tightly restricted, separated from ordinary access, and monitored. Privileged actions are recorded so that they remain reviewable and accountable.

Service-to-service access

Automated access between systems follows the same principles as access by people: each system authenticates, is authorized only for its specific role, and is denied any capability outside that role.

Auditability

Access decisions — both grants and denials — for sensitive operations are recorded in a manner that supports monitoring, investigation, and accountability.

Access review and revocation

Access is reviewed periodically to confirm it remains appropriate, and is promptly revoked when it is no longer needed or when an identity should no longer hold it.

Governance

This policy is owned by the security function and reviewed at least annually, or sooner in response to material changes in our services, threats, or obligations.